Tarea detección, correlación y acción

1.2 Ficheros STIX

- ¿Quién es el autor del informe?
  La Oficina Federal de Investigaciones (FBI), la Agencia de Seguridad Cibernética y de Infraestructuras (CISA) y el Centro Multiestatal de Intercambio y Análisis de Información (MS-ISAC) publicaron este informe en conjunto.
- ¿De qué adversario trata el informe?
  Vice Society, operando con el ransomware Medusa en su variante como RaaS.
- ¿Cómo clasificarías a este adversario dentro de los seis tipos que hemos visto?
  Lo clasificaría como Cibercrimen porque su motivación principal es el beneficio económico mediante la extorsión.
- ¿En qué año se identificó por primera vez actividad de este adversario?
  Fue identificado por primera vez en junio de 2021.
- ¿Está relacionado con algún otro adversario conocido?
  No está relacionado con la variante MedusaLocker ni con la variante de malware móvil Medusa. Sin embargo, sí existe una asociación técnica entre el nombre Vice Society y la operación Medusa Ransomware confirmada por las referencias externas.
- ¿Qué vulnerabilidades suele explotar este adversario? (CVE y explicación breve del producto afectado y la vulnerabilidad)
  Principalmente explota dos fallos en programas que las empresas usan para gestionar datos: el **CVE-2023-0669**, que afecta a GoAnywhere MFT y les permite ejecutar código a distancia para tomar el control del servidor; y el **CVE-2022-24990**, que afecta a los discos duros en red (NAS) de la marca TerraMaster, permitiéndoles enviar comandos al equipo sin necesidad de contraseña para robar o borrar la información.
- ¿Qué 5 direcciones de e-mail aparecen como indicadores?
  i. key.medusa.serviceteam@protonmail.com
  ii. medusa.support.team@protonmail.com
  iii. medusa.recovery.help@protonmail.com
  iv. help.medusa.service@protonmail.com
  v. support.medusa.key@protonmail.com
- ¿Qué finalidad crees que cumplen estas direcciones de e-mail para el adversario y sus víctimas?
  Sirven como canal de Mando y Control (C2) y negociación de forma que permiten a las víctimas contactar con los atacantes para recibir instrucciones de pago y se utilizan para gestionar la entrega de las llaves de descifrado tras el pago del rescate.
- ¿Qué técnicas descritas en la matriz de MITRE ATT&CK utiliza el adversario para el comando y control (TA0011 - Command and Control)? (Código identificador y nombre de la técnica / subtécnica)
  - T1071.001 - Application Layer Protocol: Web Protocols: Utilizan protocolos web estándar (como HTTP o HTTPS) para que el tráfico malicioso se camufle entre la navegación normal de la empresa y pase desapercibido por los firewalls.
  - T1105 - Ingress Tool Transfer: Esta técnica la usan para descargar herramientas adicionales o piezas de malware desde sus servidores externos hacia el equipo de la víctima una vez que ya han conseguido entrar.
- Entre las herramientas utilizadas por el adversario se encuentran Mimikatz, Anydesk y Certutil. Para cada una de ellas, contesta a las siguientes preguntas:
  - ¿Se encuentra por defecto en Windows?
  - ¿La categorizarías como malware?
  - Si no la categorizarías como malware, ¿por qué aparece el informe?

  i. **Mimikatz**
    - **¿Se encuentra por defecto en Windows?** No. Es una herramienta externa que el atacante debe descargar e instalar en el equipo comprometido.
    - **¿La categorizarías como malware?** Técnicamente no es malware en sí, es una herramienta legítima de pentesting creada para auditorías de seguridad. Sin embargo, como se usa tan frecuentemente en ataques reales para robar credenciales (extracción de contraseñas desde la memoria), prácticamente todos los antivirus la detectan y bloquean directamente como HackTool o software potencialmente peligroso.
    - **¿Por qué aparece en el informe?** Porque es la herramienta "estrella" de los atacantes para volcar las contraseñas almacenadas en la memoria de Windows y así conseguir las credenciales del Administrador del Dominio.

  ii. **AnyDesk**
    - **¿Se encuentra por defecto en Windows?** No. Es un software de terceros, aunque es muy popular y legítimo para dar soporte técnico remoto.

- **¿La categorizarías como malware?** No. Es una herramienta completamente legítima de administración remota, como TeamViewer.
- **¿Por qué aparece en el informe?** Porque los atacantes la instalan para mantener el acceso persistente al sistema. Si el administrador de la red detecta y cierra sus "puertas traseras" habituales, todavía pueden seguir entrando cómodamente a través de AnyDesk como si fueran técnicos de soporte legítimos.

iii. **Certutil**

- **¿Se encuentra por defecto en Windows?** Sí. Es una utilidad de línea de comandos nativa de Windows diseñada para gestionar certificados digitales.
- **¿La categorizarías como malware?** No. Es un componente oficial y legítimo del sistema operativo de Windows.
- **¿Por qué aparece en el informe?** Porque tiene una funcionalidad que permite descargar archivos desde Internet usando el parámetro `-urlcache`. Los atacantes abusan de esta característica para descargar sus herramientas maliciosas o scripts sin levantar sospechas, ya que muchos sistemas de seguridad confían en procesos firmados por Windows como `certutil.exe`. Es lo que llamamos "Living off the Land".

1.3 Expresiones Regulares

¿Cuál es el nombre de equipo (FQDN) del propio firewall del que proviene la traza syslog?

paloalto.evil.corp

Atributo	Valor	Expresión regular	Grupo de captura
Categoría	THREAT	`cat\s*=\s*(?P<categoria>[^|]+)`	categoria
Subtipo	virus	`Subtype\s*=\s*(?P<subtipo>[^|]+)`	subtipo
Timestamp	May 06 2025 16:43:53 GMT	`devTime\s*=\s*(?P<timestamp>[^|]+)`	timestamp
IP origen	10.2.75.41	`src\s*=\s*(?P<ip_origen>[^|]+)`	ip_origen
IP destino	192.168.178.180	`dst\s*=\s*(?P<ip_destino>[^|]+)`	ip_destino
Regla	Test-1	`RuleName\s*=\s*(?P<regla>[^|]+)`	regla
Usuario	ealderson	`usrName\s*=\s*(?P<usuario>[^|]+)`	usuario
Aplicación	web-browsing	`Application\s*=\s*(?P<aplicacion>[^|]+)`	aplicacion
Sistema Virtual	vsys1	`VirtualSystem\s*=\s*(?P<sistema_virtual>[^|]+)`	sistema_virtual
Zona Origen	INSIDE-ZN	`SourceZone\s*=\s*(?P<zona_origen>[^|]+)`	zona_origen
Zona Destino	OUTSIDE-ZN	`DestinationZone\s*=\s*(?P<zona_destino>[^|]+)`	zona_destino
Puerto Origen	63508	`srcPort\s*=\s*(?P<puerto_origen>\d+)`	puerto_origen
Puerto Destino	80	`dstPort\s*=\s*(?P<puerto_destino>\d+)`	puerto_destino
Protocolo	tcp	`proto\s*=\s*(?P<protocolo>\w+)`	protocolo
URL	badguys.co/du/uploads/08052018_UG_FAQ.pdf	`Miscellaneous\s*=\s*"(?P<url>[^"]+)"`	url
Categoría URL	educational-institutions	`URLCategory\s*=\s*(?P<categoria_url>[^|]+)`	categoria_url
Dominio	badguys.co	`Miscellaneous\s*=\s*"(?P<dominio>[^\/"]+)`	dominio

Atributo	Valor	Expresión regular	Grupo de captura
Nombre Fichero	08052018_UG_FAQ.pdf	`Miscellaneous\s*=\s*"[^"]*\/(?P<nombre_fichero>[^"\/]+)"`	nombre_fichero
Firma	trojan/PDF.gen.eiez	`ThreatID\s*=\s*(?<firma>[^(\s]+)`	firma
ID firma	268198686	`ThreatID\s*=\s*.*?\((?P<id_firma>\d+)\)`	id_firma

Nota: En el caso de SourceZone, el PDF al copiar inserta un salto de línea, así que asumí que esto podría pasar en otros atributos e inserté `\s*` para que se encuentre el atributo buscado sin importar si hay saltos de línea o espacios inesperados antes o después de los símbolos de igualdad.

1.4 Splunk

- ¿Cuántos eventos hay en el índice “botsv1”?
  Se busca en el índice botsv1 y con la función estadística `count` se cuenta la cantidad total de eventos.
  SPL
  ```
  index=botsv1 | stats count
  ```
  Resultado
  33413777
- ¿Cuáles son los tres “sourcetype” con más eventos por sourcetype en el índice “botsv1”?
  Se busca en el índice botsv1, luego se hace un `count` agrupando por sourcetype. De esta forma se tiene la cantidad de eventos por sourcetype, a continuación se ordenan y se toman las 3 primeras posiciones que al estar ordenadas son precisamente los sourcetypes con mayor cantidad de elementos.
  SPL
  ```
  index=botsv1 | stats count by sourcetype | sort - count | head 3
  ```
  Resultado

sourcetype	count
WinEventLog	14236319
fortigate_traffic	7675023
suricata	5078376

- ¿Cuántos eventos contienen la palabra “ellyn.baltimore”?
  Se busca en el índice botsv1 aplicando el filtro "ellyn.baltimore". De esta forma se encuentran solo los eventos que contengan esta palabra, luego se aplica la función estadística `count`.
  SPL
  ```
  index=botsv1 "ellyn.baltimore" | stats count
  ```
  Resultado
  590
- ¿Cuáles son los tres servidores (host) que más eventos han generado que contengan la palabra “ellyn.baltimore”?
  Se busca en el índice botsv1 con el filtro "ellyn.baltimore", luego se aplica un `count` agrupando por host, se ordena y una vez ordenados se toman solo los 3 primeros de la lista.
  SPL
  ```
  index=botsv1 "ellyn.baltimore" | stats count by host | sort - count | head 3
  ```
  Resultado

host	count
we9748srv	4
we2024srv	3
we3068srv	3

- ¿Según la auditoría de seguridad de Windows, cuáles han sido los 4 programas ejecutados más veces por Bree.Moser (source="wineventlog:security" EventCode=4688 user=Bree.Moser) durante el 12/08/2016?
  En el índice botsv1 se filtra por los campos mencionados y la fecha del 12/08/2016 (en formato MM/DD/YYYY), luego se agrupa por procesos para tener la lista de los programas, se ordena y se toman los 4 primeros de la lista ordenada.
  SPL

```
index=botsv1 source="WinEventLog:Security" EventCode=4688
user=Bree.Moser earliest="08/12/2016:00:00:00" latest="08/12/2016:23:59:59"
| stats count by process
| sort - count
| head 4
```

Resultado

process	count
C:\Windows\system32\DllHost.exe /Processid:{7006698D-2974-4091-A424-85DD0B909E23}	2
C:\Windows\System32\WiFiTask.exe	1
C:\Windows\SysWOW64\DllHost.exe /Processid:{1EF75F33-893B-4E8F-9655-C3D602BA4897}	1
"C:\Windows\system32\backgroundTaskHost.exe" -ServerName:App.AppXwmnqm0nvq2b90pwvr42qmtdjp7cj3w82.mca	1

- ¿Cuáles han sido los 5 sitios (site) externos (dest_ip pública) más visitados (sourcetype="stream:http")?
  Se hace una búsqueda en botsv1 filtrando por sourcetype como indica en la pregunta, luego se eliminan del resultado de la búsqueda las IP que no sean públicas, tales como las de redes corporativas, entornos con red virtual y local. Luego se agrupa por site, se ordena y se toman los 5 primeros.
  SPL

```
index=botsv1 sourcetype="stream:http"
| search NOT (dest_ip=10.0.0.0/8 OR dest_ip=172.16.0.0/12 OR dest_ip=192.168.0.0/16)
| stats count by site
| sort - count
| head 5
```

Resultado

site	count
ssw.live.com	11186
cdn.content.prod.cms.msn.com	1171
ctldl.windowsupdate.com	805
tile-service.weather.microsoft.com	399
update.joomla.org	373

- ¿Qué endpoints (host) ordenados por número descendente de conexiones tienen más de 640 conexiones de red registradas por sus agentes de Sysmon? (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=3)
  Se busca en el índice botsv1 con los filtros mencionados en la pregunta, luego se agrupa por host y se hace una consulta `where` para tomar los que tengan más de 640 eventos. Por último, se ordena para que aparezcan ordenados por número descendente.
  SPL

```
index=botsv1 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=3
| stats count by host
| where count > 640
| sort - count
```

Resultado

host	count
we8105desk	53336
we1149srv	40835
we9748srv	5749
we9041srv	5149
we1864srv	2548
we5364srv	2513
we4999srv	830
we4781srv	804
we4915srv	797

- ¿Cuáles han sido los 8 nombres de ejecutables (process) que han originado procesos más anómalos en el equipo “we8105desk” según los eventos de Sysmon? La respuesta debe incluir los nombres de cada ejecutable en MAYÚSCULAS, su recuento y el porcentaje que representa del total. (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 host=we8105desk)
  Se busca en el índice botsv1 con los filtros mostrados en la pregunta, luego se crea una columna nueva en la que se asigna el valor del proceso o ejecutable en mayúsculas. Después se calcula por cada ejecutable el total de eventos y usando esto se calcula el porcentaje para guardarlo en otra columna. Luego se ordena y se toman los 8 primeros, finalizando con un comando `table` para mostrar la información en formato de tabla.
  SPL

```
index=botsv1 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1 host=we8105desk
| eval process_name=upper(process)
| stats count by process_name
| eventstats sum(count) as total_eventos
| eval porcentaje=round((count/total_eventos)\*100, 2)
| sort - count
| head 8
| table process_name, count, porcentaje
```

Resultado

host	count	porcentaje
DLLHOST.EXE	60	10.20
CMD.EXE	50	8.50
CONHOST.EXE	48	8.16
NGEN.EXE	34	5.78
MSCORSVW.EXE	31	5.27
SEARCHPROTOCOLHOST.EXE	28	4.76
WMIPRVSE.EXE	26	4.42
SEARCHFILTERHOST.EXE	24	4.08

- El equipo de sistemas observa actividad extraña en los servidores web y sospechas que alguien haya intentado explotar una vulnerabilidad de Path Traversal conocida por el equipo de desarrollo pero que aún no habían resuelto. Para contestar con certeza, revisas el tráfico HTTP

(sourcetype="stream:http") del que dispones en Splunk y sabes que un signo evidente de intento de explotación de estas vulnerabilidades es la presencia de ".." (dos puntos seguidos) en la URL (uri) de una solicitud HTTP. ¿Puedes determinar si alguna IP ha realizado solicitudes que puedan indicar que estaba intentando explotar esta vulnerabilidad y en qué país está o están ubicadas?
Se busca en el índice botsv1 con el filtro mostrado en la pregunta y además por los que tengan en la uri la cadena "..". Usando `*` indicamos que puede estar cualquier otra cadena de caracteres delante y detrás de "..". Luego se filtra por las IP externas para asegurar que no sea un log generado por alguna prueba interna de los desarrolladores o un equipo de auditoría. A continuación se obtiene con el comando `iplocation` el src_ip para obtener las IP del posible atacante así como su país de origen, y se agrupa por la misma para obtener la cantidad de intentos de ataque con la técnica de Path Traversal.

SPL

```
index=botsv1 sourcetype="stream:http" uri="*..*"
| search NOT (src_ip=10.0.0.0/8 OR src_ip=172.16.0.0/12 OR src_ip=192.168.0.0/16)
| iplocation src_ip
| stats count by src_ip, Country
| sort - count
```

Resultado

src_ip	Country	count
40.80.148.42	United States	67

- ¿Puedes confirmar si hay algún tipo de comunicación HTTP (sourcetype="stream:http") hacia IPs públicas hacia algún puerto (dest_port) poco común (diferente al 80)? En caso afirmativo, ¿cuál es la IP (dest_ip) y el dominio (site)?
  Para ello se filtra por el índice botsv1, luego se aplican los filtros mostrados en la pregunta y el filtro `NOT dest_port=80` para evitar que lleguen eventos con el puerto destino 80. Luego se filtran las peticiones que no tienen como IP destino un dominio local. Para finalizar se obtiene la IP destino, el puerto destino y el dominio.

  SPL

```
index=botsv1 sourcetype="stream:http" NOT dest_port=80
| search NOT (dest_ip=10.0.0.0/8 OR dest_ip=172.16.0.0/12 OR dest_ip=192.168.0.0/16)
| stats count by dest_ip, dest_port, site
| sort - count
```

  Resultado

dest_ip	dest_port	site	count
23.22.63.114	1337	prankglassinebracket.jumpingcrab.com:1337	2

- El equipo de sistemas te avisa de comportamiento sospechoso en el equipo "we1149srv" (host) y te pide confirmar si se ha ejecutado (EventCode=1) algún programa (app) malicioso en los eventos de Sysmon (sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"). Como primera aproximación, decides cargar tu listado de hashes SHA256 de malware conocido (malicious-executable-hashes.csv) como lookup table para determinar si el hash (SHA256) de algún proceso lanzado coincide con los del listado. En caso de que alguno coincida, indica la descripción que ofrece el indicador y describe brevemente de qué tipo de malware se trata.
  Una vez cargada la lista de hashes maliciosos, se hace una búsqueda en el índice botsv1 con los filtros proporcionados, luego se usa una expresión regular para extraer el sha256 limpio y se coloca en una columna diferente en mayúsculas para evitar errores por letras en minúsculas. Luego se obtienen del lookup los datos haciendo coincidir el sha256 del evento con los del lookup, además se exporta la descripción contenida en el lookup para mostrarlo después. Para terminar se presenta en formato de tabla.
  Sí hay coincidencia, la descripción del indicador es el propio nombre técnico del malware: **Meterpreter_Implant**, que es un malware de post-explotación, un troyano de acceso remoto que permite a un atacante controlar el equipo infectado de forma total y secreta para espiar o robar datos.

  SPL

```
index=botsv1 sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" EventCode=1
| rex field=Hashes "SHA256=(?<sha256_hash>[^,]+)"
| eval sha256_hash = upper(sha256_hash)
| lookup malicious-executable-hashes.csv SHA256 AS sha256_hash OUTPUT Description
| search Description=*
| table _time, host, Image, sha256_hash, Description
```

Resultado

_time	host	Image	sha256_hash	Description
2016-08-10 23:56:18	we1149srv	C:\inetpub\wwwroot\joomla\3791.exe	EC78C...FA45D	Meterpreter_Implant

Nota: He cortado el hash para evitar que la tabla haga scroll y no se vea completa. **Hash SHA256 completo:** `EC78C938D8453739CA2A370B9C275971EC46CAF6E479DE2B2D04E97CC47FA45D`

- Entre el tráfico HTTP (sourcetype="stream:http") saliente hacia IPs públicas (dest_ip no privada), determina cuántas solicitudes HTTP se han realizado al TLD de cada dominio (site). Es decir, si el site="whatever.microsoft.com", el TLD de ese dominio será "com". Ordena los resultados de TLD con más solicitudes a TLD con menos solicitudes.
  Se busca en el índice botsv1 con el filtro mostrado en la pregunta. Luego se filtran las IP destino públicas. A continuación se usa una expresión regular para obtener el TLD del dominio (site). Para terminar se agrupa por TLD y se ordena el resultado final.
  SPL

```
index=botsv1 sourcetype="stream:http"
| search NOT (dest_ip=10.0.0.0/8 OR dest_ip=172.16.0.0/12 OR dest_ip=192.168.0.0/16)
| rex field=site "\.(?<tld>[a-zA-Z]+)$"
| stats count by tld
| sort - count
```

Resultado

tld	count
com	14036
org	374
net	176
io	1